Cryptography & Key Management (CBOM)

Ref: 4.2
Product: iConnect Plus
Organisation: Cache Digitech
Classification: Internal — Confidential
Version: 2.0
Date: 2026-11-03
Deployment model: On-premises (Cache Digitech premises) · VPN for remote access
Audience: Security assessors, platform engineering, IT infrastructure

---

1. Purpose

Document the **cryptographic bill of materials (CBOM)** and **key management** practices for iConnect Plus on **Cache Digitech on-premises** infrastructure. **AWS KMS is not the primary key store** in this model; secrets live on-premises (`.env` , restricted files, optional HSM if deployed).

2. Cryptographic inventory

ID	Use case	Algorithm / mechanism	Where applied	Key material location
CRYPTO-01	TLS to users	TLS 1.2+ (nginx)	Edge `erp-nginx` :8443	`docker/nginx/certs/erp.crt` / `erp.key`
CRYPTO-02	Password storage	bcrypt	API — `sec_user.password_hash`	Per-password salt (in hash)
CRYPTO-03	Session / API auth	HS256 JWT	HttpOnly cookies	`JWT_SECRET_KEY` in host `.env`
CRYPTO-04	Field-level PII/finance	Fernet (AES-128-CBC + HMAC)	Selected ORM columns	`FIELD_ENCRYPTION_KEYS`, `PII_ENCRYPTION_KEY`
CRYPTO-05	MFA	TOTP (RFC 6238)	Optional user MFA	Server-side secret per user
CRYPTO-06	Refresh tokens	Hashed at rest	`sec_refresh_token`	Pepper/hash — not reversible
CRYPTO-07	MinIO	SSE optional / TLS internal	Object API	MinIO root keys in `.env`
CRYPTO-08	PostgreSQL	TLS optional client↔DB	Docker network	**Template / Pending sign-off**
CRYPTO-09	Redis	Optional AUTH	`erp-redis`	**Template / Pending sign-off**

3. In-transit protection



Zone	Requirement
Remote users	VPN mandatory before TLS to application

Internal LAN	TLS on reverse proxy; no requirement to expose API on public internet
Container east-west	Docker bridge; restrict host firewall to admin paths

Certificate lifecycle: **Template / Pending sign-off** (issuer, renewal calendar, owner).

---

4. At-rest protection

Layer	Control	Status
Application columns	Fernet via platform encryption helpers	Implemented
Database files	Full-disk encryption on host	**Template / Pending sign-off**
MinIO objects	Volume encryption + access keys	**Template / Pending sign-off**
Backups	Encrypted backup media or encrypted dumps	**Template / Pending sign-off**
`.env` / secrets	File permissions, root-only on host	Operational

---

5. Key management (on-premises)

Secret	Rotation trigger	Procedure owner	Evidence
TLS cert/key	Expiry / compromise	IT + Platform	**Template / Pending sign-off**
`JWT_SECRET_KEY`	Annual or incident	Platform	**Template / Pending sign-off**
Fernet keys	Compromise or policy	Platform	Re-encryption runbook **Template / Pending sign-off**
MinIO credentials	Quarterly (target)	IT	**Template / Pending sign-off**
DB superuser password	Quarterly (target)	IT	**Template / Pending sign-off**

Optional HSM: If Cache Digitech deploys HSM on premises, map keys CRYPTO-03/04 to HSM slots — **Template / Pending sign-off**.

Explicit non-primary: AWS KMS, cloud secret managers as **primary** runtime key store — **not used** in this deployment model.

---

6. Key generation & storage rules

1. No cryptographic keys in Git repositories or Docker image layers.
2. Production `.env` only on application host(s); access limited to break-glass accounts.
3. Fernet key rotation requires planned maintenance — invalidates unreadable ciphertext if keys dropped without re-encrypt.
4. JWT secret rotation invalidates active sessions — communicate maintenance window.
5. Development may use local `.env.example` placeholders — never production values.

---

7. Dependencies with cryptographic impact

Component	Version (typical)	Crypto relevance
Python `cryptography`	Via requirements lock	Fernet, TLS helpers
`passlib` / bcrypt	Via requirements lock	Password hashing
`python-jose` / PyJWT	Via requirements lock	JWT HS256
OpenSSL (nginx image)	Alpine bundle	TLS termination

PostgreSQL 16	Container image	Optional TLS

Full dependency versions: see **2.7 Software Bill of Materials**.

8. Compliance mapping (summary)

Requirement	Control
Protect credentials	bcrypt + HttpOnly JWT
Protect sensitive PII	Fernet + RBAC
Protect data in transit	TLS on internal proxy
Key custody	On-prem secrets; IT + Platform

9. Related documents

Ref	Document
4.1	Data Inventory & Classification
1.5	Asset & Component Inventory
5.3	Hardening Configuration Baseline
2.1	Application Security Requirements

10. Change log

Date	Change	By
2026-11-03	v2.0 on-prem CBOM	Platform

Approved by: Template / Pending sign-off